

Vortex Tech Internship – Week 1



OWASP Top 10 Vulnerabilities Research Report

Name: Fatima Noor

Track: Cyber Security

Introduction

The OWASP Top 10 is a list of important security risks in web applications. The latest general version is OWASP Top 10, 2025. It helps developers understand common security problems and how to prevent them.

For this task, I selected five vulnerabilities from the current OWASP Top 10:2025:

1. A06:2025 – Insecure Design
2. A07:2025 – Authentication Failures
3. A08:2025 – Software or Data Integrity Failures
4. A09:2025 – Security Logging & Alerting Failures
5. A10:2025 – Mishandling of Exceptional Conditions

1. A06:2025 – Insecure Design

What is it?

Insecure Design happens when security is not properly considered while designing an application. The problem is with the way the system is planned or designed, not necessarily with the code itself. For example, a banking application may not have a proper security check before allowing an important transaction.

How can an attacker exploit it?

An attacker may look for weaknesses in the application's normal workflow. If an important security rule was never included in the design, the attacker may find a way to perform an action that should not be possible.

Real-World Example

Capital One Data Breach (2019): Capital One suffered a major data breach in which an attacker accessed the personal information of more than 100 million customers. The incident involved weaknesses in the cloud environment and access-control design. It demonstrates how security weaknesses in system architecture and design can contribute to serious data exposure.

Prevention

Developers should think about security before coding. They can use threat modeling, define security requirements, consider possible attack scenarios, and use secure design patterns.

2. A07:2025 – Authentication Failures

What is it?

Authentication Failures happen when an application does not properly verify a user's identity. Examples include weak passwords, poor session management, hard-coded credentials, and weak login protection.

How can an attacker exploit it?

An attacker may try stolen passwords, guess weak passwords, use automated login attempts, or take advantage of a weak session system. If successful, the attacker may gain access to another person's account.

Real-World Example

2023 23andMe Incident: Attackers used credential stuffing, using passwords obtained from other sources, to access user accounts. The incident demonstrated the risks of password reuse and insufficient account protection.

Prevention

Developers should support multi-factor authentication, limit repeated login attempts, use secure password storage, protect sessions, and encourage users to use strong and unique passwords. OWASP includes issues such as hard-coded passwords and session fixation under this category.

3. A08:2025 – Software or Data Integrity Failures

What is it?

This vulnerability occurs when an application trusts software, updates, or data without checking whether they have been changed or come from a trusted source.

For example, an application may automatically install an update without checking its authenticity.

How can an attacker exploit it?

An attacker may modify an update, plugin, library, or other data that the application trusts. If the application does not verify it, the malicious content may be accepted and executed.

Real-World Example

SolarWinds Supply Chain Attack (2020): Attackers compromised the SolarWinds software build process and inserted malicious code into legitimate software updates. Customers

unknowingly downloaded the compromised updates, allowing attackers to gain access to affected organizations. This demonstrates the danger of trusting software updates without properly verifying their integrity.

Prevention

Developers should verify software and data before using them, use digital signatures, use trusted repositories, and make sure updates have not been modified. OWASP specifically recommends mechanisms such as digital signatures to verify integrity.

4. A09:2025 – Security Logging & Alerting Failures

What is it?

This happens when an application does not properly record or report important security events. Good logging helps security teams understand what happened when an attack occurs.

How can an attacker exploit it?

An attacker may take advantage of poor logging because their activities are less likely to be noticed. For example, if repeated failed login attempts are not recorded or monitored, a brute-force attack may continue for a long time without being detected.

Real-World Example

Healthcare Data Breach: OWASP describes a case involving a children's health plan provider where attackers accessed and modified sensitive health records of more than 3.5 million children. The organization did not have sufficient logging and monitoring, so the breach could have continued undetected for more than seven years. This shows how inadequate logging and monitoring can allow attackers to remain undetected for a long time.

Prevention

Applications should record important security events, protect logs from unauthorized access, avoid putting sensitive information in logs, and create alerts for suspicious activities such as repeated failed logins. OWASP emphasizes that logging without useful alerting has limited value.

5. A10:2025 – Mishandling of Exceptional Conditions

What is it?

Mishandling of Exceptional Conditions happens when an application does not properly handle unexpected situations, errors, or unusual conditions.

For example, if a website crashes or behaves incorrectly when it receives unexpected input, it may create a security problem.

How can an attacker exploit it?

An attacker may intentionally create unusual situations, such as sending unexpected input or causing a system error. If the application handles the error badly, it may reveal sensitive information, bypass a security check, or behave in an unsafe way.

Real-World Example

Financial Transaction Error: OWASP describes a scenario where an attacker interrupts a multi-step financial transaction using a network disruption. If the application does not properly roll back the transaction after an error, an attacker could potentially cause money to be transferred multiple times or drain an account. This demonstrates how improper handling of unexpected conditions can lead to serious financial impact.

Prevention

Developers should handle errors properly, avoid showing sensitive technical details to users, test unusual situations, and make sure the application fails safely instead of giving access or information to an attacker. OWASP identifies improper error handling and “failing open” as examples in this category.

Personal Reflection

The vulnerability that surprised me most was Mishandling of Exceptional Conditions because I did not realize that improper error handling could become a security vulnerability. I initially thought errors were mainly a usability issue, but I learned that detailed error messages can expose sensitive information and help attackers. This showed me that even unexpected situations need to be considered during secure application development. Overall, this research helped me understand the OWASP Top 10 in a more practical way and made me realize that security needs to be considered throughout the whole development process. Even simple security practices, when applied properly during development, can significantly reduce the chances of an application being successfully attacked.